

Legal Risk Memo - Penetration Testing and Cybercrime Compliance

To: Client

From: Cybersecurity Legal Analyst

Subject: Legal Risks and Compliance Requirements for Penetration Testing (CFAA & RCW 9A.90)

This memo outlines the primary legal risks associated with penetration testing under U.S. federal law (Computer Fraud and Abuse Act, 18 U.S.C. § 1030) and Washington State cybercrime law (RCW 9A.90). It also explains how to mitigate liability through proper authorization and indemnification.

1. Five Illegal Actions Without Authorization:

- **Unauthorized Access:** Accessing a computer system without permission violates CFAA §1030(a)(2) and RCW 9A.90.040.
- **Exceeding Authorized Access:** Using legitimate credentials to access data or systems beyond approved scope is illegal under CFAA §1030(a)(2).
- **Intentional Damage:** Causing system impairment, service disruption, or data corruption violates CFAA §1030(a)(5).
- **Trafficking in Passwords or Access Credentials:** Sharing or distributing login credentials is prohibited under CFAA §1030(a)(6).
- **Obtaining Information by Deception:** Social engineering without explicit authorization may violate RCW 9A.90.060 (computer trespass).

2. Difference Between Federal and Washington State Law:

The CFAA focuses heavily on the concept of 'exceeding authorized access,' meaning even partial misuse of legitimate credentials can trigger federal liability. Washington State law (RCW 9A.90), however, emphasizes 'unauthorized access' as a broader category and does not rely as heavily on the distinction between authorized and exceeding authorized access.

3. Liability Mitigation - Indemnification:

Penetration testers can protect themselves through indemnification clauses in the Rules of Engagement. Indemnification ensures the client accepts responsibility for accidental damage (e.g., server crashes) that occurs during authorized testing, provided the tester acted within scope and without negligence.

End of memo.